

Revisao de seguranca operacional

Revisão de segurança operacional

****Data:**** 13/09/2026

****API testada:**** `http://127.0.0.1:8891`

****Resultado:**** Aprovado nos checks executados

Evidências HTTP

| Verificação | Resultado |

|---|---|

| `GET /health` | HTTP `200`, status `healthy` |

| `GET /health/ready` | HTTP `200`, banco PostgreSQL e LM Studio `true` |

| `GET /api/projetos` sem token | HTTP `401`, autenticação exigida |

| `GET /api/projetos` com token inválido | HTTP `401`, token rejeitado |

Controles confirmados

- JWT é exigido nos endpoints protegidos.
- Token inválido ou expirado é rejeitado.
- Verificação de prontidão testa dependências reais (PostgreSQL e LM Studio).
- Rate limit por IP está habilitado no middleware da API.
- Auditoria de ações do copiloto permanece habilitada no banco.

Pendências operacionais

- Executar teste de carga do rate limit em ambiente controlado.
- Rotacionar `AUTH\_SECRET` forte em produção e armazená-lo fora do repositório.
- Configurar monitoramento externo e alertas de indisponibilidade.